

AtlasPay FinTech

SOC 2 Type 1 Readiness - Audit Walkthrough

DOCUMENT ID

**IFESEC-ATL-SOC2-
AW-20260625**

VERSION

v3.0

PERIOD

FY 2026 Q3 Audit Window

PREPARER

IfeSec - ijezie Risk Advisory

CLASSIFICATION

CONFIDENTIAL

STATUS

Draft - Pending Review

[LAB-SYNTHETIC]

AtlasPay SOC 2 Type 1 Audit Walkthrough Simulation

Document Type: Audit Walkthrough Packet **Engagement:** AtlasPay SOC 2 Type 1 Readiness **Date:** 2026-06-26
Prepared by: Ijezie Risk Advisory **Document Version:** 1.0 **Status:** Final

Purpose

This packet simulates a SOC 2 Type 1 audit walkthrough. It contains 10 questions a SOC 2 auditor would ask AtlasPay personnel during a real engagement, expected findings (14 total), and management response templates for each finding. Use this to train AtlasPay's team, identify documentation gaps before the real audit, and demonstrate IfeSec's audit-readiness methodology.

Walkthrough Questions and Expected Findings

Question 1: Logical Access Controls (CC6.1, CC6.2, CC6.3)

Auditor asks: "Show me how you provision and deprovision user access for production systems. How do you ensure terminated employees lose access within 24 hours?"

AtlasPay should answer:

- New user: HR ticket triggers Auth0 user creation with role assignment based on job description. Manager approval required before activation.
- Termination: HR system triggers Auth0 user disable within 1 hour of termination notice. Quarterly attestation of existing privileged accounts.
- Evidence: Auth0 audit logs, HR ticket trail, quarterly attestation reports.

Expected finding F-01 (Medium): Quarterly privileged access attestation is documented as a process but has not yet been executed (first run scheduled Q4 2026). Compensating control: Auth0 joiner/leaver automation is operational.

Management response: AtlasPay will run the first quarterly privileged access attestation in Q4 2026 (POA&M-02). Until then, Auth0 joiner/leaver automation provides the primary control.

Question 2: Audit Logging (CC7.1, CC7.2, CC7.3)

Auditor asks: "Walk me through how a privileged user login event is captured, where it's stored, and how long it's retained."

AtlasPay should answer:

- Auth0 emits `s.login.success` and `s.login.fail` events to Datadog via the audit log forwarder (Helix-era, retained for AtlasPay).
- Datadog retention: 90 days hot, 1 year cold archive.

-
- Alert rules: 5+ failed logins in 5 minutes triggers PagerDuty.

Expected finding F-02 (Low): Audit log integrity depends on Datadog availability - separate dependency not currently documented in BCP. Datadog failure would result in log loss.

Management response: AtlasPay will document Datadog availability as a separate dependency in the BCP (POA&M-12) and consider secondary log forwarding to S3 Glacier for 7-year retention.

Question 3: Incident Response (CC7.3, CC7.4, CC7.5)

Auditor asks: "Tell me about your last security incident. How was it detected, escalated, contained, and resolved?"

AtlasPay should answer:

- Most recent incident: October 2025 BEC attempt targeting finance team. Detected via anomaly in payment velocity. Contained within 4 hours, no funds transferred. IRP followed.
- Tabletop exercise planned for Q1 2027 to validate IR readiness.

Expected finding F-03 (Low): Tabletop exercise has not yet been executed. IRP is documented but not yet validated via simulation.

Management response: AtlasPay will execute BEC tabletop exercise in Q1 2027 (POA&M-10) and document lessons learned for IRP update.

Question 4: Change Management (CC8.1)

Auditor asks: "Show me the change log for a recent production deployment. Who approved it, what testing was done, and how was the rollout controlled?"

AtlasPay should answer:

- GitHub PR with 2+ reviewer approval required.
- CI/CD pipeline runs automated tests (unit, integration, security scan).
- Staging deployment + manual smoke test before production rollout.
- Rollback plan documented in PR description.

Expected finding F-04 (None): Change management process is well-documented and operational. No findings.

Question 5: Vendor Risk Management (CC3.4, CC9.2)

Auditor asks: "Walk me through how you onboard a new vendor. How do you assess their security posture? What contractual protections do you require?"

AtlasPay should answer:

- Vendor onboarding: procurement ticket → TPRM review → security questionnaire → SOC 2 report request → contract addendum → tier assignment.
 - Current state: 7 vendors in scope. 0 vendors with current SOC 2 Type 2 reports on file.
-

Expected finding F-05 (High): Vendor SOC 2 Type 2 report collection is incomplete. Without vendor reports, AtlasPay cannot demonstrate that critical vendors meet equivalent security controls.

Management response: AtlasPay will collect SOC 2 Type 2 reports from all Tier 1 vendors by Q1 2027 (POA&M-03). For vendors without reports, compensating controls (continuous security rating monitoring, contractual breach notification SLA) will be documented.

Question 6: Risk Assessment (CC3.1, CC3.2, CC3.3)

Auditor asks: "How do you identify and assess risks? How frequently is the risk register reviewed?"

AtlasPay should answer:

- Annual risk assessment + quarterly review cadence (in development).
- 6 risk scenarios in current register, scored on 5x5 ISO 27005 matrix.
- Board reporting: ad-hoc (not yet formalized).

Expected finding F-06 (Medium): Board-level security KPI reporting cadence is not formalized. Quarterly board meetings receive security updates bundled into operational risk reports, but no dedicated security report exists.

Management response: AtlasPay will establish quarterly board security report cadence in Q1 2027, with template covering risk register changes, POA&M status, incident summary, vendor risk summary, audit readiness (POA&M for CC1.2/CC4.2).

Question 7: Data Classification and Confidentiality (C1.1)

Auditor asks: "How do you classify data? What protections apply to confidential vs. public data?"

AtlasPay should answer:

- Data classification: 3 tiers (Public, Internal, Confidential). Policy documented but formalization pending.
- Confidential data: encrypted at rest (AES-256) and in transit (TLS 1.3), access restricted via RBAC.

Expected finding F-07 (Medium): Data classification policy is documented but not formally approved and disseminated. Staff awareness of classification levels is inconsistent.

Management response: AtlasPay will formally approve and disseminate the data classification policy in Q1 2027, with training module for all employees (linked to POA&M-13 annual security awareness).

Question 8: Backup and Recovery (A1.3, CC7.5)

Auditor asks: "How frequently are backups taken? When was the last successful restore test?"

AtlasPay should answer:

- Database backups: continuous (point-in-time recovery, 35-day retention).
- File backups: daily snapshots, 90-day retention.
- Restore test: monthly automated verification + quarterly full restore test.

Expected finding F-08 (None): Backup and recovery process is well-documented and tested. No findings.

Question 9: Security Awareness Training (CC1.4, CC1.5)

Auditor asks: "How do you ensure all employees complete annual security awareness training? What's the completion rate?"

AtlasPay should answer:

- Annual training via KnowBe4 or similar platform.
- Quarterly phishing simulations.
- Current completion rate: 80% (target: 100%).

Expected finding F-09 (Low): Security awareness training completion rate is below 100% target. 20% of employees have overdue training.

Management response: AtlasPay HR will enforce training completion by tying it to performance review process (Q4 2026). Target: 100% completion by Q1 2027.

Question 10: Physical and Environmental Controls (CC6.4)

Auditor asks: "How do you restrict physical access to your production infrastructure?"

AtlasPay should answer:

- All production workloads on AWS (no on-prem data centers).
- AWS SOC 2 Type 2 report inherited for physical controls.
- Office: badge access, visitor log, security cameras.

Expected finding F-10 (None): Physical controls are inherited from AWS SOC 2. Office controls are appropriate for a FinTech of this size. No findings.

Findings Summary

#	FINDING	SEVERITY	LINKED POA&M
F-01	Quarterly privileged access attestation not yet executed	Medium	POA&M-02
F-02	Audit log Datadog dependency not documented in BCP	Low	POA&M-12
F-03	IRP tabletop exercise not yet executed	Low	POA&M-10
F-04	(No finding) Change management operational	-	-
F-05	Vendor SOC 2 Type 2 report collection incomplete	High	POA&M-03
F-06	Board security KPI reporting cadence not formalized	Medium	(POA&M for CC1.2/CC4.2)
F-07	Data classification policy not formally approved	Medium	(POA&M for C1.1)
F-08	(No finding) Backup and recovery operational	-	-

#	FINDING	SEVERITY	LINKED POA&M
F-09	Security awareness training completion below 100%	Low	POA&M-13
F-10	(No finding) Physical controls inherited from AWS	-	-

Total findings: 10 (1 High, 3 Medium, 3 Low, 3 No-finding).

Audit-Readiness Recommendation

AtlasPay is NOT audit-ready today. A real SOC 2 Type 1 audit in Q3 2026 would surface F-01, F-05, F-06, F-07 as audit exceptions and likely result in a qualified opinion.

Path to audit-ready (Q2 2027):

- 1. Execute POA&M-02 (quarterly access attestation) - Q4 2026
- 2. Codify vendor onboarding checklist and begin SOC 2 collection - Q4 2026
- 3. Document data classification policy - Q1 2027
- 4. Establish quarterly board security reporting - Q1 2027
- 5. Collect Tier 1 vendor SOC 2 reports - Q1 2027
- 6. Execute IRP tabletop exercise - Q1 2027

After these 6 actions, AtlasPay reaches 95%+ readiness and can engage a SOC 2 audit firm for Q2 2027 audit window.

[LAB-SYNTHETIC] This walkthrough simulation is a portfolio demonstration artifact for Ijezie Risk Advisory's vCISO capability. AtlasPay is a fictional FinTech persona; the questions and findings are illustrative patterns for SOC 2 audit preparation.

Ijezie Risk Advisory - Solo vCISO consulting, NIST-first methodology, SOC 2 / ISO 27001 / HIPAA / FFIEC.